

Encuesta Integral GRC de Ciberseguridad en España (2026)

Versión 1.0 – Borrador para validación por CISOs, responsables de riesgo y cumplimiento.

Ámbito: organizaciones públicas y privadas con operación en España.

0. Información general de la organización

0.1. Tipo de organización

- ☐ Administración pública (AGE, CCAA, EELL)
- ☐ Empresa pública
- ☐ Empresa privada – gran empresa (≥ 250 empleados)
- ☐ Empresa privada – pyme (< 250 empleados)
- ☐ Operador de servicios esenciales / entidad importante (NIS2)
- ☐ Entidad regulada financiera (DORA)
- ☐ Otra (especificar): _____

0.2. Sector principal de actividad

- ☐ Energía
- ☐ Agua
- ☐ Transporte
- ☐ Salud
- ☐ Finanzas / seguros
- ☐ TIC / servicios digitales
- ☐ Industria / manufactura
- ☐ Administración / servicios públicos
- ☐ Educación / investigación
- ☐ Otro (especificar): _____

0.3. Tamaño aproximado (empleados)

- ☐ < 50
- ☐ 50–249
- ☐ 250–999
- ☐ 1.000–4.999
- ☐ ≥ 5.000

0.4. Persona que responde

- Cargo: _____
- Área:
- ☐ Dirección general
- ☐ Seguridad / CISO
- ☐ TI / CTO / CIO
- ☐ Riesgos / cumplimiento
- ☐ Auditoría interna
- ☐ Otra (especificar): _____

1. Gobernanza de la ciberseguridad

1.1. Estrategia y modelo de gobierno

P1.1.1. ¿La organización dispone de una estrategia formal de ciberseguridad aprobada por el máximo órgano de gobierno?

- ☐ No existe
- ☐ Existe de facto, pero no está formalmente aprobada
- ☐ Aprobada hace más de 3 años, no revisada
- ☐ Aprobada en los últimos 3 años, sin revisiones periódicas definidas
- ☐ Aprobada y revisada con una frecuencia mínima anual, con actas y evidencias

P1.1.2. La estrategia de ciberseguridad está alineada explícitamente con:

(Seleccione todas las que apliquen)

- ☐ Estrategia global de negocio
- ☐ Estrategia digital / transformación digital
- ☐ Estrategia de gestión de riesgos corporativos (ERM)
- ☐ Estrategia de continuidad de negocio y resiliencia
- ☐ Estrategia de sostenibilidad / ESG
- ☐ No existe alineamiento documentado, pero se asume “por sentido común”
- ☐ No está alineada con nada reconocible, pero se habla muy bien de ella

P1.1.3. ¿Existe un apetito de riesgo de ciberseguridad definido y aprobado por la dirección?

- ☐ No, el riesgo es percibido solo de forma cualitativa e informal
- ☐ Sí, definido de forma cualitativa (baja / media / alta tolerancia)
- ☐ Sí, con límites numéricos (p. ej. máximos de pérdida esperada, RTO/RPO sectoriales, etc.)
- ☐ Sí, y se revisa al menos anualmente
- ☐ Sí, y se usa para priorizar explícitamente inversiones y proyectos

1.2. Roles, responsabilidades y rendición de cuentas

P1.2.1. ¿Quién ostenta la máxima responsabilidad ejecutiva sobre ciberseguridad?

- ☐ No está claramente definido
- ☐ CIO / responsable de TI
- ☐ CISO (dependiente de TI)
- ☐ CISO (dependiente de riesgo / cumplimiento / dirección general)
- ☐ Otro (especificar): ____

P1.2.2. El CISO (o equivalente):

- ☐ No existe como rol formal
- ☐ Existe, pero sin independencia ni acceso a la alta dirección
- ☐ Reporta a TI sin acceso directo al consejo
- ☐ Reporta a dirección de riesgos / dirección general con acceso regular al consejo
- ☐ Es miembro del comité de dirección y participa en el consejo cuando se tratan riesgos críticos

P1.2.3. ¿Existen comités formales de ciberseguridad o de riesgos tecnológicos?

- ☐ No
- ☐ Sí, pero se reúnen de forma ad hoc
- ☐ Sí, con reuniones periódicas definidas (al menos semestrales)
- ☐ Sí, con reuniones trimestrales o superiores, y actas documentadas
- ☐ Sí, y sus decisiones se integran en el cuadro de mando corporativo

1.3. Métricas y reporting de gobernanza

P1.3.1. ¿Se dispone de un cuadro de mando de ciberseguridad?

- ☐ No
- ☐ Sí, pero limitado a métricas técnicas (vulnerabilidades, antivirus, etc.)
- ☐ Sí, incluye métricas técnicas y de procesos (incidentes, tiempos de respuesta, auditorías)
- ☐ Sí, incluye además indicadores de riesgo y de alineamiento con negocio
- ☐ Sí, se integra en el cuadro de mando corporativo y se revisa en consejos / comités

P1.3.2. Frecuencia de reporte de ciberseguridad al máximo órgano de gobierno

- ☐ Nunca
- ☐ Solo tras incidentes graves
- ☐ Anual
- ☐ Semestral
- ☐ Trimestral o más frecuente (por supuesto, con PowerPoint)

2. Gestión del riesgo de ciberseguridad

2.1. Metodología y alcance

P2.1.1. ¿La organización aplica una metodología formal de gestión de riesgos de ciberseguridad?

- ☐ No
- ☐ Sí, propia no alineada con estándares
- ☐ Sí, basada en ISO 31000 / ISO 27005
- ☐ Sí, basada en NIST RMF / NIST CSF
- ☐ Sí, basada en marcos nacionales (ENS, guías CCN, etc.)
- ☐ Combinación de las anteriores (explicar en comentarios)

P2.1.2. Alcance actual de la gestión de riesgos de ciberseguridad

- ☐ Solo TI corporativa
- ☐ TI + OT en áreas críticas
- ☐ TI + OT + proveedores clave
- ☐ Toda la organización, incluyendo cadena de suministro y terceros críticos
- ☐ Abarca además riesgos de privacidad y protección de datos

2.2. Identificación, análisis y valoración

P2.2.1. ¿Con qué frecuencia se realiza un análisis formal de riesgos de ciberseguridad?

- ☐ Nunca
- ☐ Solo antes de auditorías o por requerimiento regulatorio
- ☐ Cada más de 2 años
- ☐ Anual
- ☐ Al menos anual, con revisiones ad hoc ligadas a cambios relevantes (nuevos proyectos, fusiones, etc.)

P2.2.2. Nivel de cuantificación de riesgos

- ☐ Exclusivamente cualitativo (bajo/medio/alto)
- ☐ Cualitativo con escalas semi-cuantitativas (1-5, 1-10)
- ☐ Se utilizan estimaciones económicas de impacto (pérdida esperada, escenario plausible)
- ☐ Se utilizan modelos actuariales o de análisis cuantitativo (p. ej. FAIR u otros)
- ☐ Se integran los riesgos de ciberseguridad en el mapa de riesgos corporativo con impactos financieros

2.3. Prioridad sectorial y criticidad

P2.3.1. ¿Se han identificado los servicios / procesos críticos para la organización y/o para el país (según NIS2, DORA, etc.)?

- ☐ No
- ☐ Sí, pero no se han mapeado a activos tecnológicos específicos
- ☐ Sí, con mapeo de servicios críticos a activos TI/OT
- ☐ Sí, con mapeo y escenarios de impacto definidos
- ☐ Sí, y se cruzan criticidad y madurez de controles para priorizar inversiones

P2.3.2. ¿Cómo se priorizan las inversiones de ciberseguridad?

- ☐ Por percepción / presión del proveedor / moda tecnológica
- ☐ Por cumplimiento regulatorio mínimo
- ☐ Por resultados de auditoría
- ☐ Por análisis de riesgo formal
- ☐ Por una combinación de análisis de riesgo, ROI esperado y resiliencia

3. Cumplimiento normativo y regulatorio

3.1. Marco regulatorio aplicable

P3.1.1. Indique qué marcos / normas resultan aplicables a su organización (marcar todos los que apliquen)

- ☐ ENS (Esquema Nacional de Seguridad)
- ☐ ISO 27001 / 27701
- ☐ NIS2 (operador esencial / entidad importante)
- ☐ DORA (entidad financiera o proveedor TIC relevante)
- ☐ RGPD / LOPDGDD
- ☐ Sectorial (p. ej. PSD2, HIPAA equivalente, PCI DSS, etc.)
- ☐ Otros (especificar): _____

P3.1.2. Nivel de cumplimiento percibido con los marcos aplicables

- ☐ Muy bajo – cumplimiento reactivo, sin planificación
- ☐ Parcial – existen iniciativas en curso sin completar
- ☐ Aceptable – cumplimiento razonable con algunas brechas conocidas
- ☐ Alto – cumplimiento sistemático, con pocas brechas residuales
- ☐ Certificado / auditado regularmente por terceros

3.2. Procesos de cumplimiento y evidencias

P3.2.1. ¿Se dispone de un inventario actualizado de controles de ciberseguridad?

- ☐ No
- ☐ Sí, pero no mapeado a requisitos normativos
- ☐ Sí, mapeado a ISO 27001 / ENS u otros
- ☐ Sí, mapeado a múltiples marcos (NIS2, DORA, etc.)
- ☐ Sí, integrado en una herramienta GRC (y, ocasionalmente, en la realidad)

P3.2.2. ¿Con qué frecuencia se revisa el cumplimiento de controles clave?

- ☐ Nunca sistemáticamente
- ☐ Solo en auditorías puntuales
- ☐ Anual
- ☐ Semestral
- ☐ Continuamente con soporte de herramientas de monitorización / GRC

4. Capacidades técnicas y Zero Trust

4.1. Identidad y acceso

P4.1.1. Nivel de madurez en gestión de identidades (IAM) y accesos privilegiados (PAM)

- ☐ Gestión manual / usuarios locales sin control centralizado
- ☐ Directorio centralizado básico (AD u otros)
- ☐ IAM con control de roles y grupos, revisiones periódicas de accesos
- ☐ IAM avanzado con SSO, MFA generalizado, PAM para accesos privilegiados
- ☐ Modelo Zero Trust basado en identidad (acceso condicional, principios de mínimo privilegio “de verdad”)

P4.1.2. Cobertura de autenticación multifactor (MFA)

- ☐ No se utiliza MFA
- ☐ Limitado a accesos VPN / remotos
- ☐ Extendido a administradores y usuarios sensibles
- ☐ Aplicado a todos los usuarios internos
- ☐ Aplicado a todos los usuarios internos y externos relevantes, incluyendo clientes y proveedores

4.2. Red, segmentación y acceso remoto

P4.2.1. Enfoque actual de arquitectura de red

- ☐ Red plana con controles perimetrales básicos
- ☐ Segmentación básica entre entornos (oficina / producción / DMZ)
- ☐ Segmentación avanzada con microsegmentación en entornos críticos
- ☐ Enfoque Zero Trust Network Access (ZTNA) en sustitución o refuerzo de VPN
- ☐ Arquitectura predominantemente cloud con principios Zero Trust integrados

P4.2.2. Uso de soluciones ZTNA / SSE / SASE

- ☐ Ninguna
- ☐ PoC / piloto
- ☐ Implantación parcial en algunos colectivos
- ☐ Implantación extendida a la mayoría de usuarios externos / remotos
- ☐ Modelo predominante de acceso a recursos internos

4.3. Datos, detección y respuesta

P4.3.1. Protección de datos sensibles (DLP / cifrado / clasificación)

- ☐ No existe clasificación formal de la información
- ☐ Clasificación básica, sin controles técnicos asociados
- ☐ Clasificación con controles de cifrado en tránsito y en reposo
- ☐ DLP implementado en correo y web para datos críticos
- ☐ Clasificación, cifrado y DLP integrados, con gobierno de datos y auditoría

P4.3.2. Capacidades de detección y respuesta (SOC, SIEM, EDR/XDR)

- ☐ Sin capacidades dedicadas (solo antivirus / firewall básico)
- ☐ Monitorización parcial mediante registros y herramientas puntuales
- ☐ SIEM centralizado con casos de uso básicos
- ☐ SOC interno o servicio gestionado 24x7 con EDR/XDR
- ☐ SOC maduro con TI + OT, caza de amenazas y playbooks automatizados

5. Resiliencia, continuidad y respuesta a incidentes

5.1. Planificación y pruebas

P5.1.1. ¿La organización dispone de planes formales de respuesta a incidentes de ciberseguridad?

- ☐ No
- ☐ Sí, borrador nunca utilizado (ni en pruebas, ni en tragedias)
- ☐ Sí, probado mediante ejercicios de escritorio
- ☐ Sí, probado mediante simulacros técnicos / red-team / purple-team
- ☐ Sí, con simulacros periódicos que involucran a negocio y alta dirección

P5.1.2. ¿Existen planes de continuidad de negocio y recuperación ante desastres (BCP/DRP) que consideren ciberincidentes?

- ☐ No
- ☐ Sí, pero no contemplan escenarios de ciberataque específicos
- ☐ Sí, con algunos escenarios de ciberataque
- ☐ Sí, con escenarios detallados por servicio crítico
- ☐ Sí, probados periódicamente con métricas de RTO/RPO y lecciones aprendidas

6. Inversión, IGM y ROI

P6.1.1. Porcentaje aproximado del presupuesto de TI dedicado a ciberseguridad

- ☐ < 5 %
- ☐ 5–10 %
- ☐ 10–15 %
- ☐ 15–20 %
- ☐ > 20 %
- ☐ No se sabe / la pregunta es ofensiva

P6.1.2. Evolución del presupuesto de ciberseguridad en los últimos 3 años

- ☐ Disminución neta
- ☐ Estable
- ☐ Aumento moderado (< 10 % anual)
- ☐ Aumento significativo (≥ 10 % anual)
- ☐ Volátil, depende de incidentes y sustos

P6.1.3. ¿La organización evalúa el retorno de la inversión (ROI) en ciberseguridad?

- ☐ No
- ☐ Sí, de forma cualitativa
- ☐ Sí, en algunos proyectos concretos
- ☐ Sí, con modelos cuantitativos (reducción de pérdida esperada, etc.)
- ☐ Sí, integrado en el proceso general de evaluación de inversiones corporativas

7. Cultura, formación y terceros

P7.1.1. Formación y concienciación en ciberseguridad

- ☐ No se realiza formación
- ☐ Formación puntual para algunos colectivos
- ☐ Formación anual para la mayoría de empleados
- ☐ Programas continuos, con simulaciones de phishing y métricas de mejora
- ☐ Formación específica para alta dirección, consejo y terceros críticos

P7.1.2. Gestión de riesgos de terceros y cadena de suministro

- ☐ No se evalúa ciberseguridad de terceros
- ☐ Se incluye en contratos cláusulas genéricas
- ☐ Se utilizan cuestionarios básicos de seguridad
- ☐ Se aplican evaluaciones periódicas de riesgo y auditorías a terceros críticos
- ☐ Se integran métricas de riesgo de terceros en el mapa de riesgos corporativo

8. Comentarios abiertos

P8.1. ¿Qué le gustaría que la política nacional de ciberseguridad hiciera mejor para ayudar a organizaciones como la suya?

Respuesta abierta:

P8.2. ¿Qué métrica de ciberseguridad le parece más útil para hablar con su consejo de administración sin que nadie se duerma?

Respuesta abierta: